



Universidad Mariano Gálvez de Guatemala

Facultad de Ingeniería en Sistemas de Información y Ciencias de la Computación

Maestría en seguridad informática

SEGURIDAD EN APLICACIONES

Tarea: Elaboración de Modelo de Amenazas Completo utilizando OWASP Threat Dragon

Objetivo

Diseñar y documentar un modelo de amenazas integral para una aplicación o servicio crítico, utilizando **OWASP Threat Dragon**, con el fin de identificar amenazas potenciales, evaluar riesgos, definir prioridades de remediación y establecer controles de seguridad tempranos dentro del SSDLC.

Alcance

La actividad contempla el análisis de la arquitectura de la solución, incluyendo:

- Componentes de negocio.
- Aplicaciones web y móviles.
- APIs y servicios de integración.
- Bases de datos.
- Infraestructura asociada.
- Flujos de información internos y externos.
- Dependencias de terceros.

Actividades a ejecutar

1. Levantamiento de Arquitectura

- Recopilar diagramas de arquitectura actuales.
- Identificar activos críticos y datos sensibles.
- Documentar componentes, interfaces y dependencias.
- Clasificar los flujos de información según criticidad.

Entregables

- Inventario de componentes.
 - Inventario de activos de información.
 - Arquitectura lógica validada.
-

2. Construcción de Diagramas de Flujo de Datos (DFD)

Utilizando OWASP Threat Dragon:

Nivel 0

- Contexto general de la aplicación.
- Sistemas externos relacionados.
- Usuarios internos y externos.

Nivel 1

- Procesos principales.
- Almacenes de datos.
- Flujos de información.
- Límites de confianza (Trust Boundaries).

Nivel 2 (cuando aplique)

- Descomposición detallada de componentes críticos.
- Integraciones bancarias, middleware y APIs.

Elementos mínimos

- External Entities

- Processes
- Data Stores
- Data Flows
- Trust Boundaries

Evidencias

- Archivos exportados de Threat Dragon.
- Capturas de los DFD generados.
- Documento descriptivo de los componentes modelados.

3. Análisis de Amenazas mediante STRIDE

Realizar la identificación de amenazas sobre cada elemento del DFD.

Categorías STRIDE

Categoría	Descripción
Spoofing	Suplantación de identidad
Tampering	Manipulación de datos
Repudiation	Negación de acciones realizadas
Information Disclosure	Exposición de información
Denial of Service	Interrupción o degradación del servicio
Elevation of Privilege	Escalamiento de privilegios

Actividades

- Revisar cada flujo de datos.
- Analizar cada proceso.
- Evaluar almacenes de datos.
- Identificar amenazas automáticamente y manualmente.
- Validar amenazas con Arquitectura y Desarrollo.

Evidencias

- Lista de amenazas generadas por Threat Dragon.
 - Matriz STRIDE consolidada.
 - Registro de validación técnica.
-

4. Priorización de Riesgos

Clasificar las amenazas identificadas utilizando criterios de impacto y probabilidad.

Criterios sugeridos

Impacto

- Crítico
- Alto
- Medio
- Bajo

Probabilidad

- Muy Alta
- Alta
- Media
- Baja

Clasificación del Riesgo

Impacto	Probabilidad	Nivel
Alto	Alto	Crítico
Alto	Medio	Alto
Medio	Medio	Medio
Bajo	Bajo	Bajo

Salida

- Matriz de riesgos.
 - Ranking de amenazas.
 - Top 10 hallazgos prioritarios.
-

5. Definición de Casos de Abuso (Abuse Cases)

Para cada amenaza crítica y alta:

Documentar

- Objetivo del atacante.
- Vector de ataque.
- Precondiciones.
- Método de explotación.
- Impacto esperado.
- Control preventivo.
- Control detectivo.
- Acción correctiva.

Ejemplos

Caso de abuso 1

- Actor: Usuario malicioso.
- Objetivo: Acceso no autorizado a cuentas.
- Amenaza STRIDE: Spoofing.
- Riesgo: Crítico.
- Mitigación: MFA, IAM y monitoreo.

Caso de abuso 2

- Actor: Atacante externo.
- Objetivo: Manipulación de transacciones.
- Amenaza STRIDE: Tampering.

- Riesgo: Alto.
- Mitigación: Integridad criptográfica y validaciones de negocio.

Evidencias

- Catálogo de casos de abuso.
 - Relación amenaza-control.
-

6. Definición de Controles de Seguridad

Mapear controles para cada amenaza identificada:

Aplicación

- Autenticación multifactor.
- Gestión de sesiones.
- Validación de entradas.
- Cifrado.

APIs

- OAuth 2.0 / OIDC.
- Rate Limiting.
- API Gateway Security.

Infraestructura

- Segmentación de red.
- Hardening.
- Gestión de secretos.

Monitoreo

- Logging centralizado.
 - SIEM.
 - Alertamiento.
-

Evidencias requeridas

Arquitectura

- Diagramas de arquitectura.
- Inventario de sistemas.
- Flujos de información.

Threat Modeling

- Proyecto OWASP Threat Dragon (.json).
- DFD Nivel 0, 1 y 2.
- Inventario de amenazas STRIDE.

Gestión de Riesgos

- Matriz de riesgos.
- Priorización de amenazas.
- Plan de remediación.

Casos de Abuso

- Catálogo de abuse cases.
- Controles asociados.
- Riesgos residuales.

Entregables

1. Informe de Modelo de Amenazas

Incluye:

- Alcance evaluado.
- Arquitectura analizada.
- DFD generados.
- Trust Boundaries identificados.
- Amenazas STRIDE detectadas.

- Casos de abuso documentados.
- Controles recomendados.

2. Repositorio OWASP Threat Dragon

- Archivo JSON del modelo.
- Diagramas exportados.
- Versionado del modelo.

3. Matriz de Riesgos y Remediación

- Riesgo identificado.
- Severidad.
- Responsable.
- Acción correctiva.
- Fecha objetivo.

4. Roadmap de Mejoras

- Hallazgos de corto plazo (0-3 meses).
- Hallazgos de mediano plazo (3-6 meses).
- Hallazgos de largo plazo (6-12 meses).

Criterios de aceptación

- DFD Nivel 0 y Nivel 1 elaborados y aprobados.
- Trust Boundaries identificados y documentados.
- Amenazas STRIDE analizadas para todos los componentes críticos.
- Riesgos priorizados y valorados.
- Casos de abuso documentados para amenazas críticas y altas.
- Controles de mitigación definidos y aprobados.
- Modelo almacenado y mantenido en OWASP Threat Dragon como artefacto oficial del SSDLC.

